

Kickoff — Security-Awareness-Programm

Kunde: **Textilcolor AG** Vorbereitung & Onboarding · Stand: 10.06.2026

1 · Was Sie erwartet

- Über mehrere Monate verschickte, realistische Phishing-Simulationen in eskalierenden Stufen (2 ? 4).
- Jeder Klick führt sofort zu einer kurzen **Microlearning-Seite**— Lernen im Moment statt Blossstellung.
- Wir messen **Verhalten**(Klick, Absenden, Meldung) — **niemals echte Passwörter** Ergebnisse pseudonymisiert und aggregiert.
- Ziel: messbar bessere Reflexe — URL prüfen, melden, im Zweifel über einen Zweitkanal verifizieren.

2 · Was wir von Ihnen brauchen — die Empfänger-Liste (CSV)

Eine einfache CSV-Datei mit den Teilnehmenden. Spalten (Reihenfolge flexibel, Kopfzeile wird automatisch erkannt):

Vorname	für die persönliche Anrede
Nachname	optional
E-Mail	zwingend — die einzige Pflichtangabe

Format: UTF-8 · Komma oder Semikolon als Trennzeichen · eine Person pro Zeile. Mehrere Listen möglich (z. B. je Abteilung S1–S8 für den Pretext-Split).

Vorname,Nachname,E-Mail
Anna,Bühler,anna.buehler@tcag.ch
Marco,Steiner,marco.steiner@tcag.ch
Sophie,Meier,sophie.meier@tcag.ch

Wir benötigen **nur** Name und E-Mail — keine Passwörter, keine HR-Daten.

3 · Technische Freigaben (vor Welle 1)

- **Allowlisting** M365 Defender (Advanced Delivery): unsere Sende-IP + Look-alike-Domain, damit Übungs-Mails nicht im Filter hängen.
- **CEO-Einverständnis** (Anhang A.4), schriftlich — für Szenarien, die Führungspersonen imitieren (K3, K4-Sub).
- **Domains/DNS** Look-alike-Domain + Sub-Domains mit eigenem Zertifikat (richten wir ein; ggf. Ihre Freigabe nötig).

4 · Wie wir kommunizieren

- **Eingeweihter Kreis klein halten** nur die für Freigaben/Eskalation nötigen Personen kennen den Zeitplan — sonst verfälscht es die Ergebnisse.
- **Awareness-Mailbox / „Phish-Button“** Mitarbeitende melden verdächtige Mails dorthin; Meldungen zählen als **positives** Verhalten.
- **Eskalation** je ein definierter Kontakt bei Ihnen und bei uns, erreichbar während aktiver Wellen.

- **Reporting** Kurz-Auswertung nach jeder Welle, Gesamt-Report am Programmende (pseudonymisiert).
- **Vertraulichkeit** Vishing-Mitschnitte nur mit Zustimmung (Art. 179bis StGB); keine echten Überweisungen (Honeypot).

5 · Zeitplan & nächste Schritte

K1 15.06.	M365 „Postfach voll“ (Baseline) — Ihre To-dos : CSV-Liste, Allowlisting, CEO-Einverständnis, Awareness-Mailbox + Eskalationskontakt.
K2 06.07.	HR-Lohn / Lieferantenrechnung (Split nach Abteilung)
Quishing 17.08.	QR-Code „Neue MA-App“
K3 07.09.	OneDrive-Sharing (CEO, OSINT)
K4 05.10.	Abteilungs-Mix (REACH / Frachtbrief / Schoeller)
K4-Sub KW43	CEO-BEC + Multi-Channel Vishing

Sobald die vier kundenseitigen Punkte erledigt sind, startet K1 am 15.06.2026. Diese Plattform dient ausschliesslich autorisierten Security-Awareness-Übungen.